

Data Protection Education (DPE) Governors GDPR Progress Report Dec 2021

DPE lead consultant and author: Stuart Lee

School lead and DPE contact: Sarah D’Rosario

Introduction and approach

The Governors report is written using the main ICO GDPR accountability tracker headings:

1. Leadership and oversight
2. Policies and procedures
3. Training and awareness
4. Individual rights and transparency
5. Record of processing, risks, lawful basis and contracts
6. Records management and security of data
7. Breach response and monitoring
8. DPE visits, dashboard and best practice area
9. DPE privacy program conclusion and next step

The report will detail the schools GDPR compliance progress for each of these areas using information obtained from visits, remote sessions and the schools use of the DPE dashboard and ticket system. The report concludes with next steps.

1. Leadership and oversight

The school has a delegated approach to their GDPR program and has always taken a proactive approach to GDPR compliance. The headteacher is involved in meetings when appropriate and a member of the leadership team is assigned to support compliance actions, with the school secretary/finance officer (Sarah) coordinating and acting as the GDPR lead/champion for the school; liaising directly with DPE with GDPR queries and concerns, supporting with updating of GDPR documentation and setting up staff on the DPE website.

2. Policies and procedures

There is a dedicated GDPR section on the school website which will have the key DPE GDPR documentation listed:

- GDPR policy
- Privacy Notice(s) and third party list of who you share information with
- Subject access request (SAR) and data breach procedure
- Consent
- FOI policy and publication scheme

The school also has a work away from school and CCTV policy documentation.

Note: The GDPR section of the school website is currently being updated with the latest documents (3/12/21).

3. Training and awareness

From reviewing the online training record the school is at an advanced stage with the GDPR training that has been completed. School staff have completed the following GDPR e-learning training:

- National Cyber Security Centre (NCSC) Stay Safe Online Training
- Data breach
- Subject access requests
- Password security
- Physical security
- Working at home
- Data classification

Where staff have yet to complete a training module, Sarah is aware of the reporting function within the DPE website to monitor, review and follow up with staff as needed.

4. Individual rights and transparency

The UK GDPR provides the following rights for individuals: The right to be informed; The right of access; The right to rectification; The right to erasure; The right to restrict processing; The right to data portability; The right to object; rights in relation to automated decision making and profiling.

The school displays privacy notice(s) on the GDPR section of the school website and staff awareness is completed in school and through DPE e-learning training.

For all subject access requests the compliance team, including DPEs senior compliance staff, barrister and solicitor would work with the school to support data subject rights including complex subject access requests. No SARs are currently logged against the school.

5. Record of processing (RoP), lawful basis and contracts

Article 30 GDPR describes the obligation to maintain a record of processing activities. This means that each controller and processor has to establish a record of each processing activity that concerns personal data. The school will use DPEs record of processing manager for their record of processing activities.

DPE has and will continue to work with the school to complete DPEs record of processing that also incorporates risk management (DPIAs), lawful basis, data retention schedules and contracts. Article 28 (3) of the GDPR states: "Processing by a processor shall be governed by

a contract or other legal act under domestic law, that is binding on the processor with regard to the controller...”

The school currently has processors identified and documented, but as above, will not have the record of processing (article 30 GDPR), including adding suppliers and contracts completed. This area will be given additional time and focus in the coming year.

6. Records management and security of data

Record management and security of data covers everything from security of data transfers, data quality, retention schedules, destruction of data, access controls, mobile devices, remote working, secure areas, acceptable software to business continuity.

From discussions with Sarah, staff and previous audits, there is good practice in place. Because of the multifaceted and complex nature of electronic records management, this area has been added as a focus for the following year.

7. Breach response and monitoring

A personal data breach is a breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to, personal data. When you’ve made this assessment, if it’s likely there will be a risk then you must notify the ICO; if it’s unlikely then you don’t have to report.

Data breaches are being logged and DPEs response protocols are followed with staff having completed data breach training. The school has 1 breach recorded for academic year 2019-20 and 1 breach recorded for academic year 2020-2021.

Any breaches reported, are monitored and will have a member of the compliance team analyse and provide support and feedback on mitigations to improve practice and raise staff awareness.

8. DPE visits, dashboard and best practice area

The school makes good use of the DPE website and best practice areas to support compliance. Breaches are recorded and the ticket system is used. Although no subject access requests (SARs) are recorded the school would use the DPE log if required for recording SARs.

The school also uses a combination of raising support tickets and emailing directly for GDPR support.

Note: Due to COVID-19 restrictions it was not possible to complete any onsite audit visits for the academic year 2020/21. Visits have started to be resumed from September 2021.

Previous reports demonstrate good progress made in areas of physical data handling and security.

9. DPE privacy program conclusion and next steps

Since subscribing to the service the school has had onsite visits, remote consultations and access to the DPE Knowledge bank for logging data breaches, subject access requests, raising tickets and for GDPR resources, including e-learning training. There continues to be a proactive approach to GDPR compliance; staff completing e-learning training; engaging with DPE for data protection support, keeping up to date with the latest developments and policy updates etc.

Focus and next steps for 2022:

Continue to raise staff awareness, especially in relation to information security.

Support the school and Sarah with the Record of processing (RoP) activities.

Records management/data retention of electronic systems.

Complete audit walks via the making the rounds app (termly).